ONE-PAGE BRIEF

Post-quantum cryptography review: aave-v3-origin @ 8305565ae342

Client: Aave DAO — public repository (passive review) · Source: github.com/aave-dao/aave-v3-origin, commit `8305565ae342` · Reviewed: 2026-10-29 06:16 UTC · Risk profile: Financial institution

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

0 Critical **9** High **3** Medium

14 Low **32** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

High QSI-2026-06514	**delegatecall usage in...** preliminary What to do: Restrict delegatecall targets to trusted, immutable implementations.
High QSI-2026-06520	**delegatecall usage in src/contracts/dependencies/openzeppelin/contracts/Address.sol** preliminary What to do: Restrict delegatecall targets to trusted, immutable implementations.
High QSI-2026-06522	**delegatecall usage in...** preliminary What to do: Restrict delegatecall targets to trusted, immutable implementations.
High QSI-2026-06523	**initialize() without initializer modifier in...** preliminary What to do: Use OpenZeppelin Initializable (initializer modifier) and disable initializers in the implementation constructor.

22 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium transaction and message signing	ECDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...

Static review of source code and manifests; files analysed: 645. No requests were sent to the owner's systems.

Full report, content SHA-256: `e7d4254918ac124d044234875cf5eaf0ca41e8942ad34749fce947e2c8940dca`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.